Table of contents:

Part 1: Reconnaissance....1
Part 2: AI-Assisted Reconnaissance.... 1
Table of contents:....2
Part 1.... 5
Reconnaissance.... 6
Task 1:Target Selection....6
* What is the program name?....6
* What is the allowed scope?....6
Ans:....6
Task 2: Subdomain & Host Discovery....7
* How many hosts are live?.... 7
* Which hosts are most interesting?.... 8
Task 3: Technology Fingerprinting.... 10
What technologies, frameworks, servers, or CMSs were identified?....10
These findings indicate that the discovered web applications use a combination of cloud infrastructure, CDNs, web servers, content-management technologies, authentication services, and front-end frameworks....10
Which findings are relevant for further testing?.... 11
● Amazon S3 and Amazon CloudFront – Cloud storage and CDN technologies that may be relevant for reviewing authorized access controls and configurations....12
These findings do not indicate that vulnerabilities exist. They are identified areas of interest based on the technology fingerprinting results and can be used to prioritize further testing within the authorized scope.... 12
Task 4: Directory & Content Discovery.... 14
Which endpoints require further investigation?....15
Task 5: URL & Endpoint Discovery....16
2. Which endpoints or parameters are interesting?.... 16
3. Were any hidden/API endpoints discovered?....17
https://advisors.vanguard.com/auth/xm1/public/models/models-ui-data.... 19
Conclusion.... 19

Part 1

Reconnaissance

Task 1:Target Selection

* What is the program name?

ans:Vanguard Vulnerability Disclosure Program

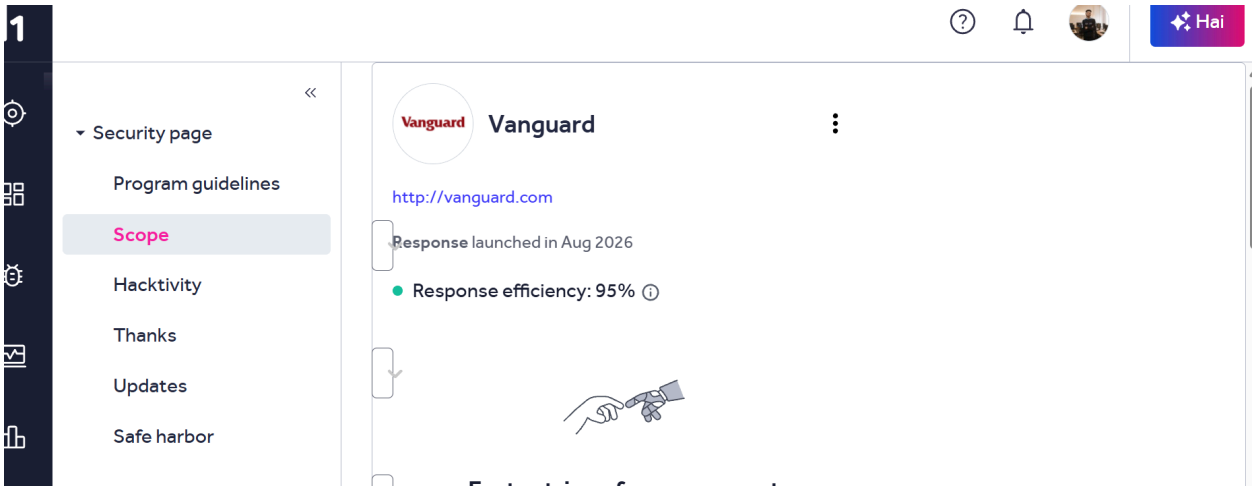
*** What is the selected target?**

Ans:*.vanguard.com

* What is the allowed scope?

Ans:

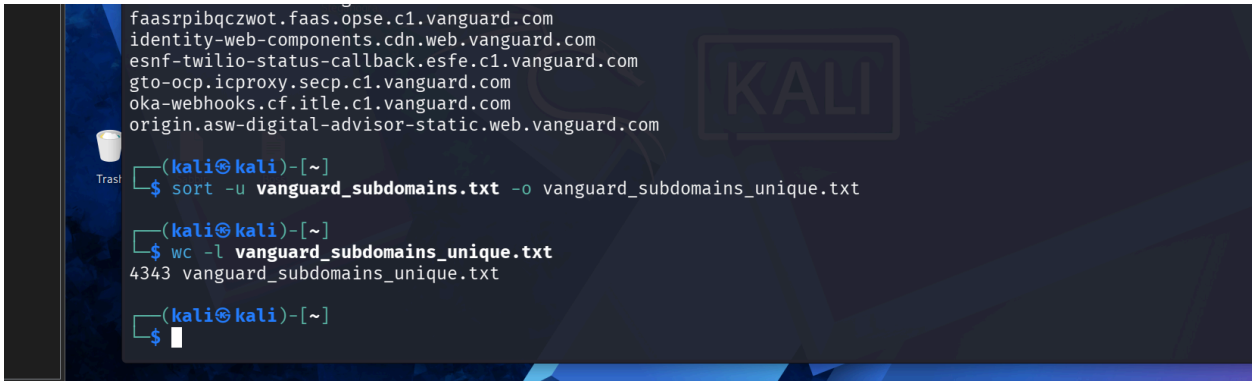
The selected target is within the authorized scope of the Vanguard Vulnerability Disclosure Program. The reconnaissance was limited to publicly accessible assets and subdomains that are explicitly listed as eligible in the program's current HackerOne scope. All activities were performed in accordance with the program's rules, scope restrictions, and rate limits.



Task 2: Subdomain & Host Discovery

*** How many unique subdomains were discovered?**

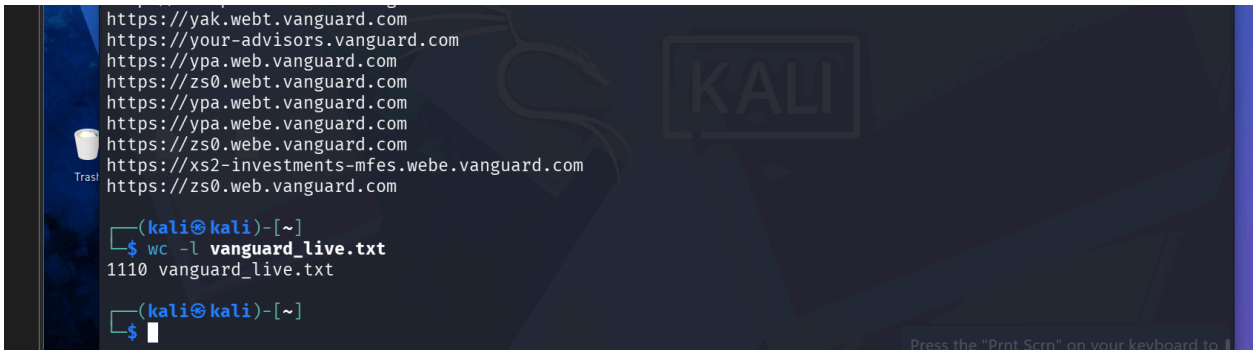
Output: **4343**

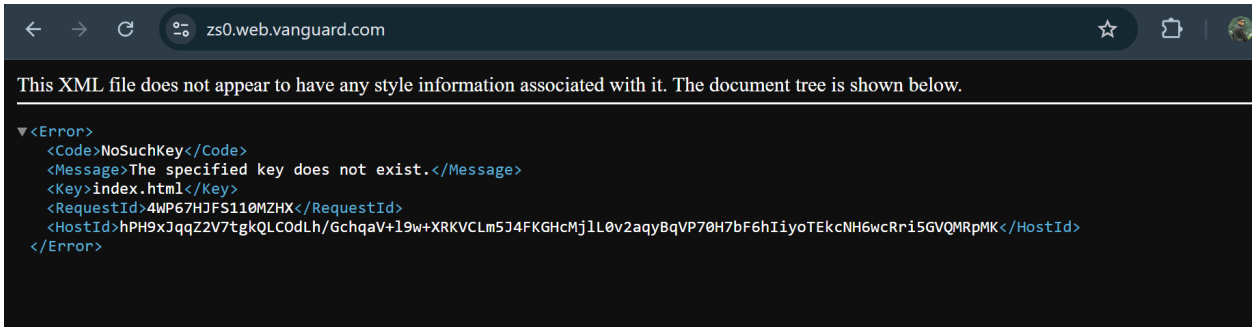


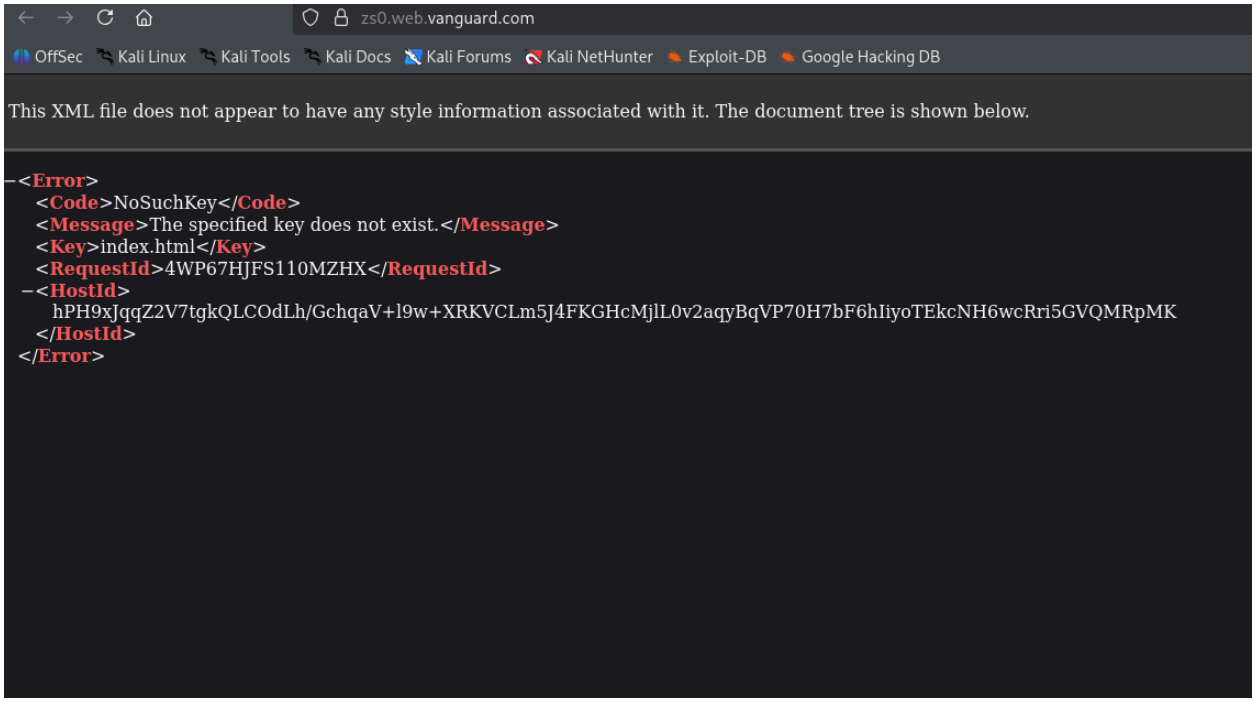
* How many hosts are live?

Ans:1110

live hosts were identified during the live-host verification.



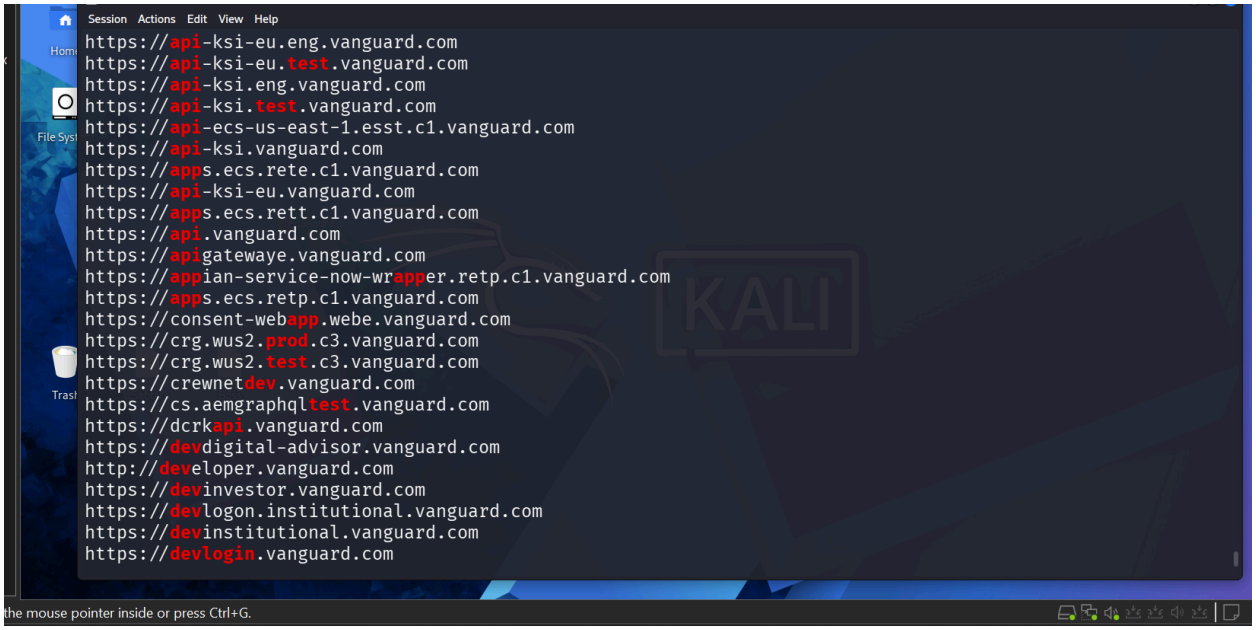


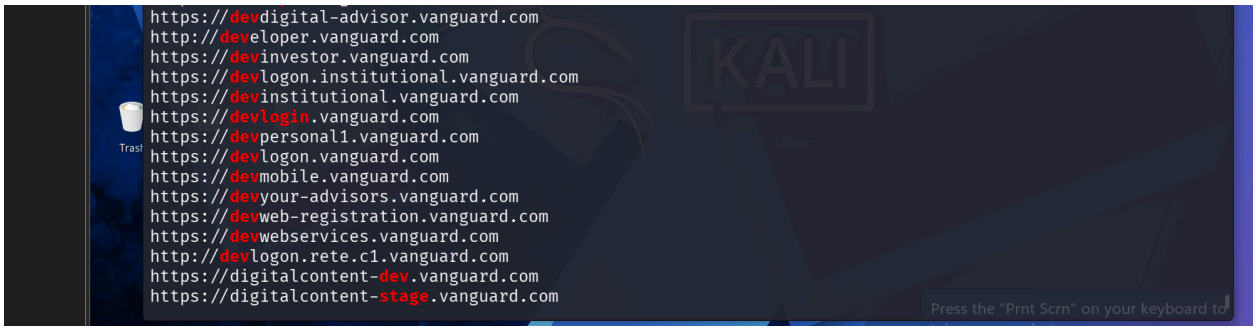


* Which hosts are most interesting?

Ans: The most interesting hosts identified were `api.vanguard.com`, `login.vanguard.com`, `oauth.vanguard.com`, `developer.vanguard.com`, and `portal.dap-orchestrator.cdn.web.vanguard.com`, as their names indicate API, authentication, developer, and portal-related services

`https://api.vanguard.com` — API endpoint
`https://login.vanguard.com` — Login/authentication service
`https://oauth.vanguard.com` — OAuth service
`https://developer.vanguard.com` — Developer-facing host
`https://portal.dap-orchestrator.cdn.web.vanguard.com` — Portal/application host



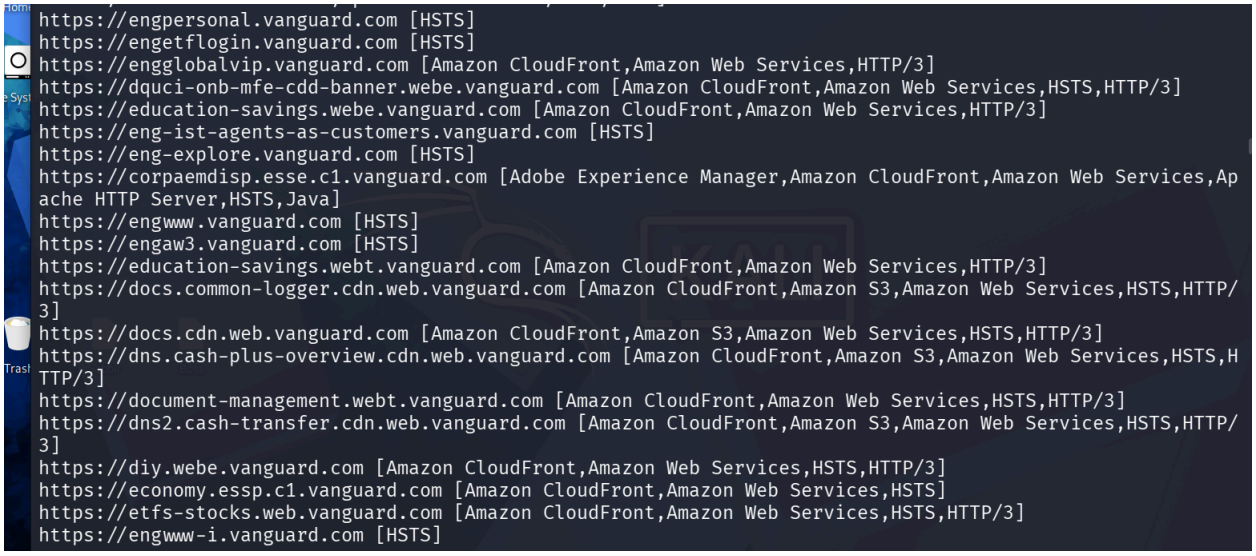


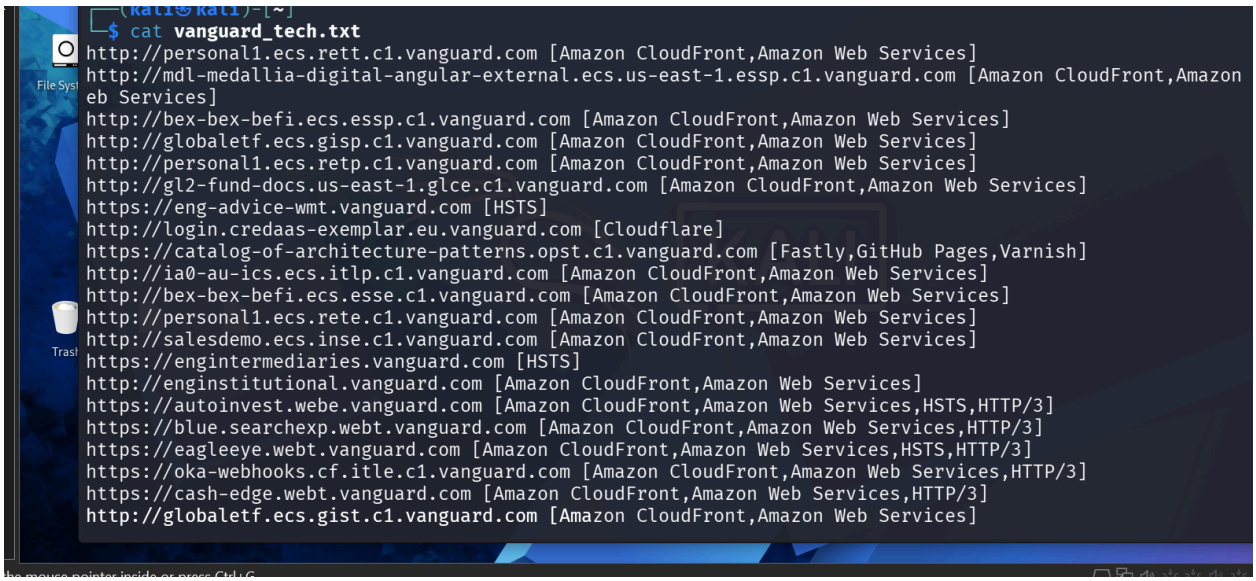
Task 3: Technology Fingerprinting

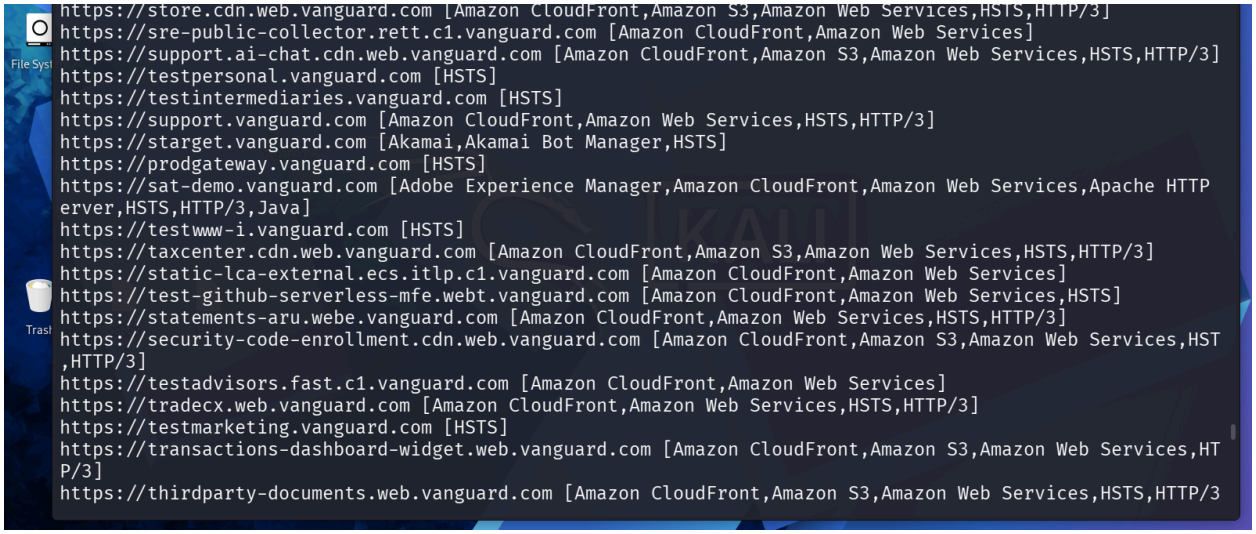
What technologies, frameworks, servers, or CMSs were identified?

The technology fingerprinting process identified a diverse technology stack across the discovered Vanguard web applications. The main technologies, frameworks, servers, and infrastructure components identified were Amazon Web Services (AWS), Amazon CloudFront, Amazon S3, Akamai, Akamai Bot Manager, Cloudflare, Cloudflare Bot Management, Fastly, Varnish, GitHub Pages, Adobe Experience Manager (AEM), Apache HTTP Server, F5 BIG-IP, Amazon Elastic Load Balancer (ELB), Auth0, Algolia, Java, jQuery, Alpine.js, Slick, HTTP/3, and HSTS.

These findings indicate that the discovered web applications use a combination of cloud infrastructure, CDNs, web servers, content-management technologies, authentication services, and front-end frameworks.





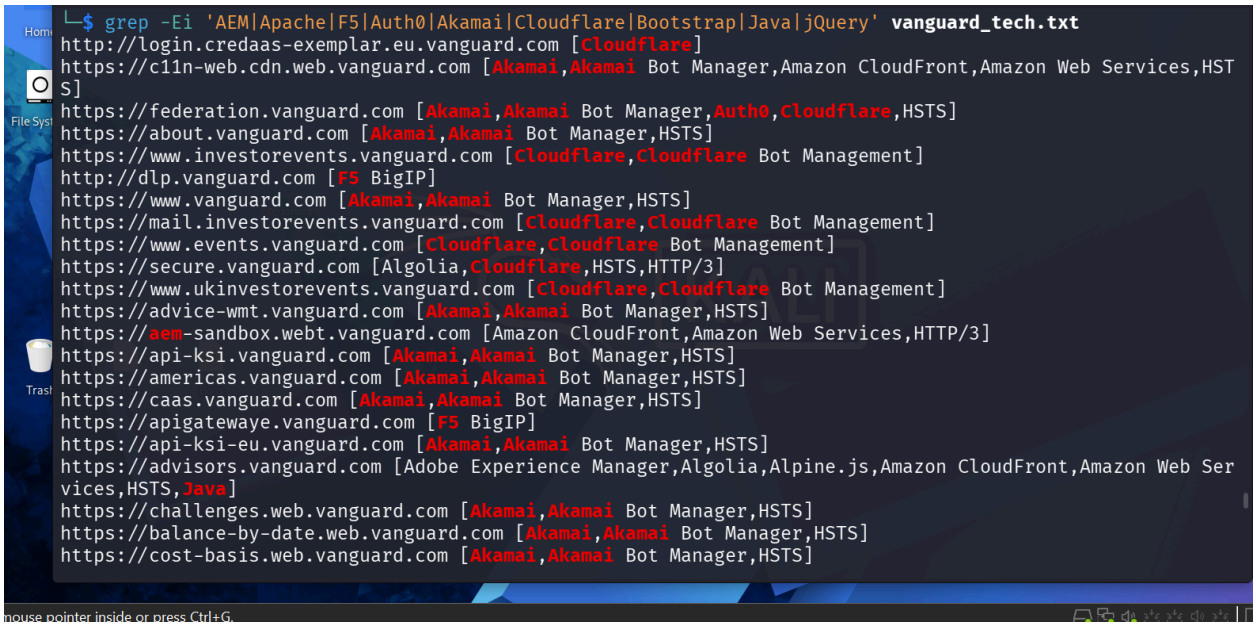


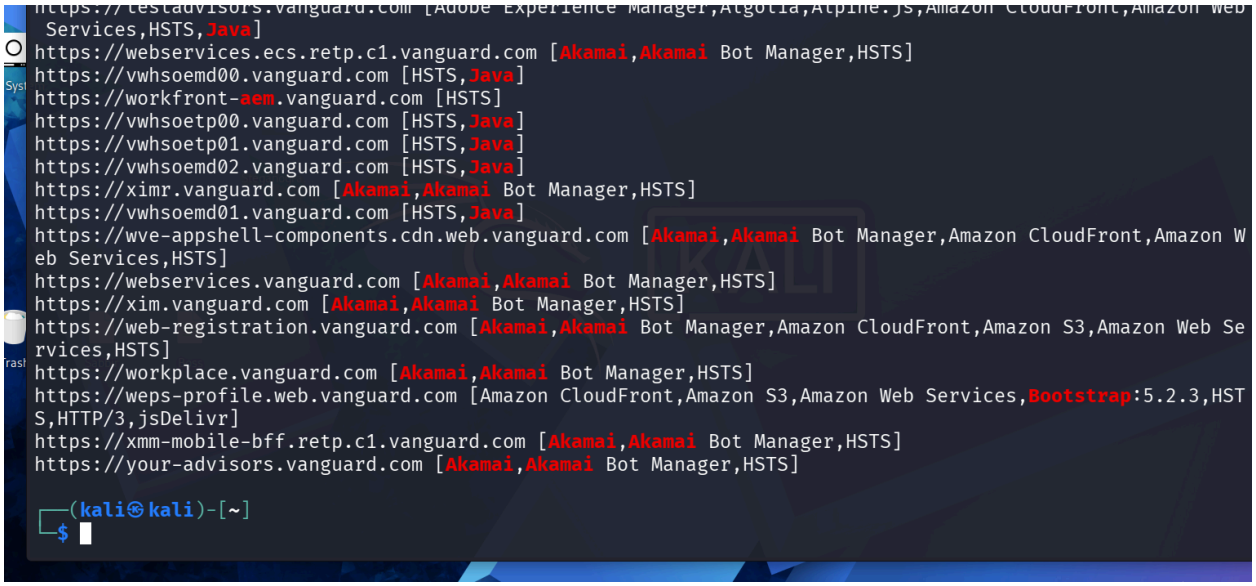
Which findings are relevant for further testing?

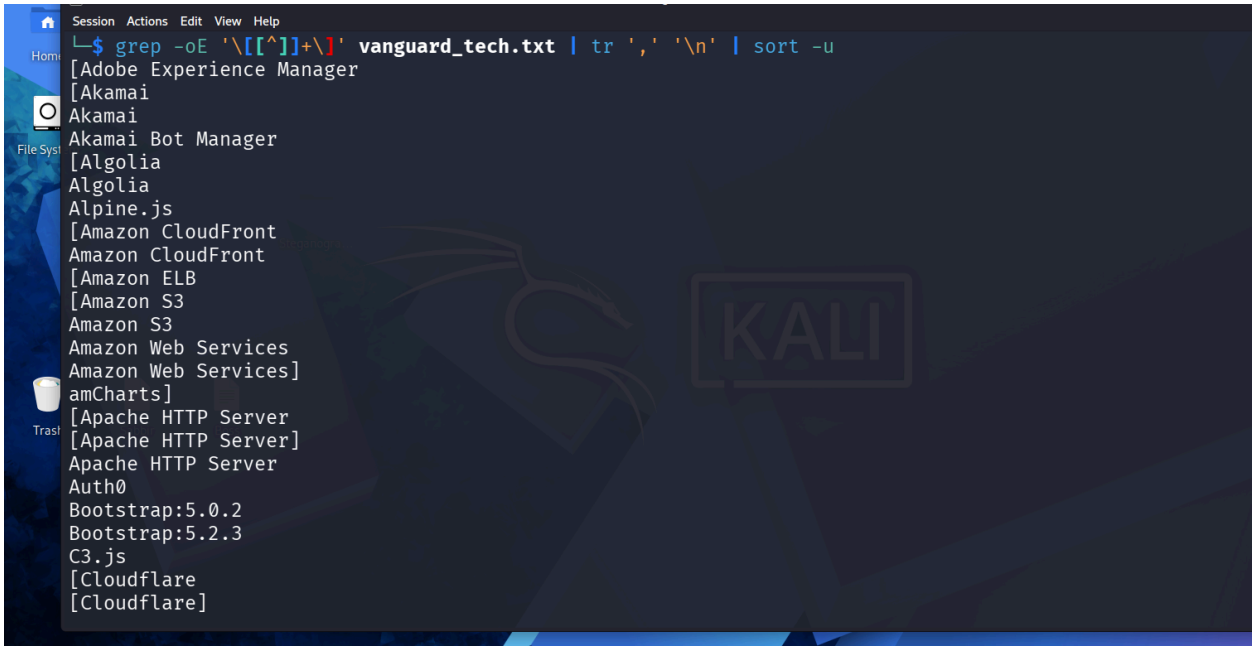
Based on the technology fingerprinting results, the following findings are considered relevant for further authorized security testing:

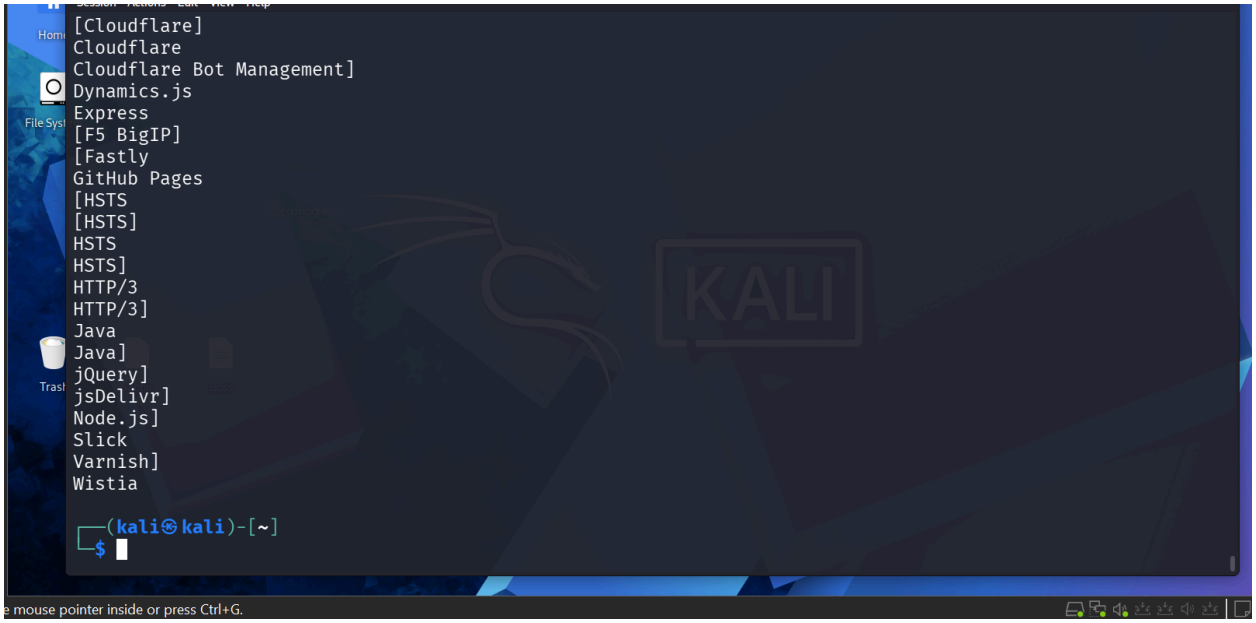
- **Adobe Experience Manager (AEM)** – CMS technology that may require security assessment of its exposed web components and configurations.
- **Apache HTTP Server** – Web server technology that can be considered when reviewing server configuration and security posture.
- **F5 BIG-IP** – Application delivery and load-balancing infrastructure that may be relevant for configuration and exposure assessment.
- **Auth0** – Authentication and identity-management technology that may be relevant for reviewing authentication-related security controls.
- **Express and Node.js** – Web application technologies that may be relevant when assessing application behavior and security configurations.
- **Amazon S3 and Amazon CloudFront** – Cloud storage and CDN technologies that may be relevant for reviewing authorized access controls and configurations.
- **Akamai and Cloudflare** – CDN, security, and bot-management technologies that can help identify the security infrastructure protecting the applications.

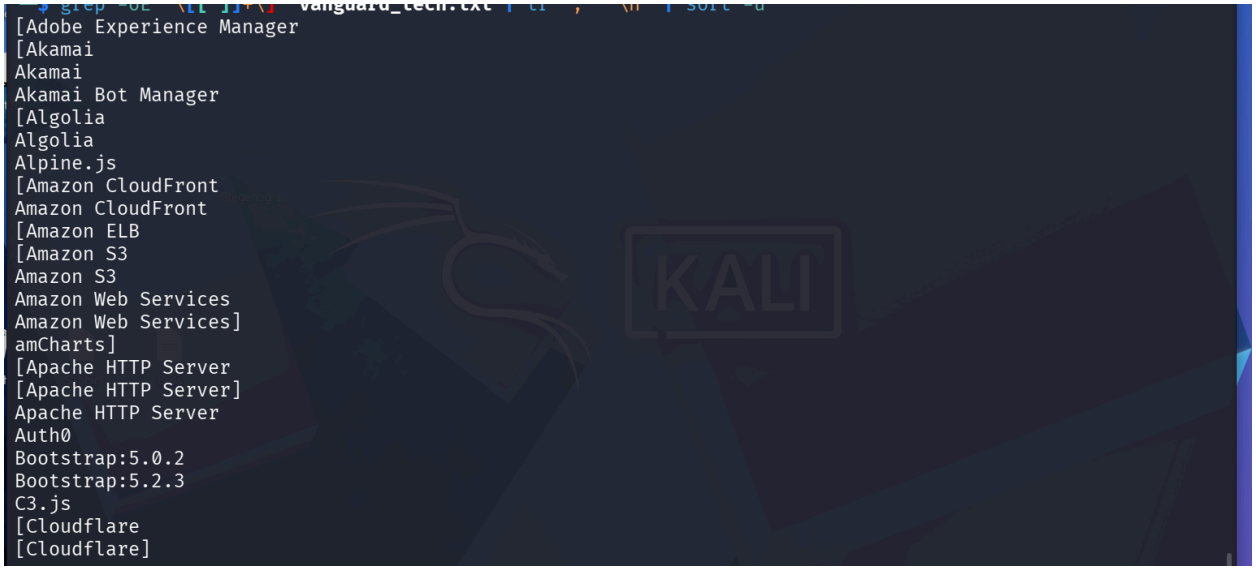
These findings do not indicate that vulnerabilities exist. They are identified areas of interest based on the technology fingerprinting results and can be used to prioritize further testing within the authorized scope.






Session Actions Edit View Help
└─$ grep -oE '\[[^]]+\]' vanguard_tech.txt | tr ',' '\n' | sort -u
[Adobe Experience Manager
[Akamai
Akamai
Akamai Bot Manager
[Algolia
Algolia
Alpine.js
[Amazon CloudFront
Amazon CloudFront
[Amazon ELB
[Amazon S3
Amazon S3
Amazon Web Services
Amazon Web Services]
amCharts]
[Apache HTTP Server
[Apache HTTP Server]
Apache HTTP Server
Auth0
Bootstrap:5.0.2
Bootstrap:5.2.3
C3.js
[Cloudflare
[Cloudflare]


[Cloudflare]
Cloudflare
Cloudflare Bot Management]
Dynamics.js
Express
[F5 BigIP]
[Fastly
GitHub Pages
[HSTS
[HSTS]
HSTS
HSTS]
HTTP/3
HTTP/3]
Java
Java]
jQuery]
jsDelivr]
Node.js]
Slick
Varnish]
Wistia
┌──(kali㉿kali)-[~]
└─$
e mouse pointer inside or press Ctrl+G.



Task 4: Directory & Content Discovery

*** Which interesting directories/files were discovered?**

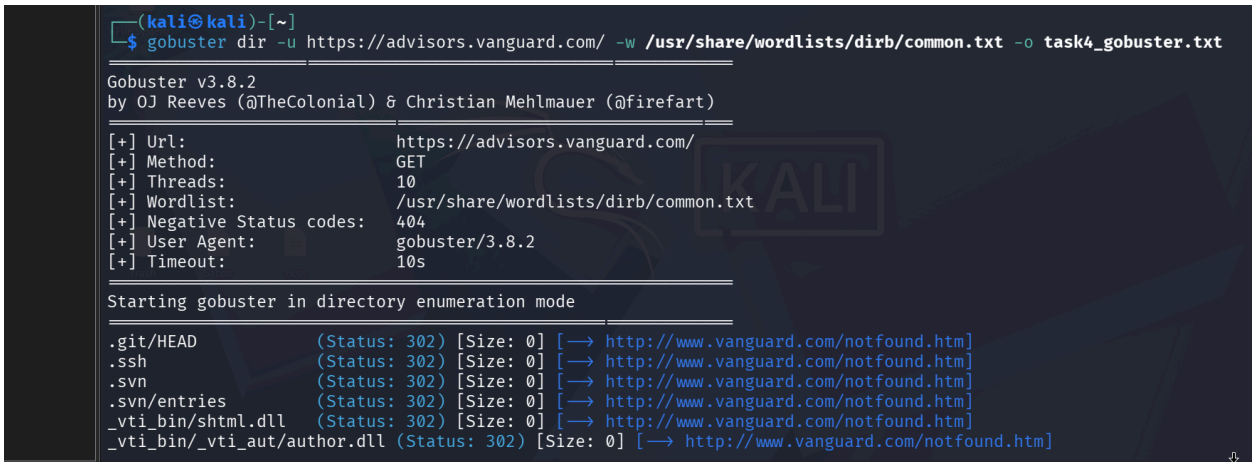
Gobuster identified several potentially interesting paths on `advisors.vanguard.com`, including `.git/HEAD`, `.ssh`, `.svn`, `.svn/entries`, `_vti_bin/shtml.dll`, `_vti_rpc`, `/auth`, and `/contact-us`.

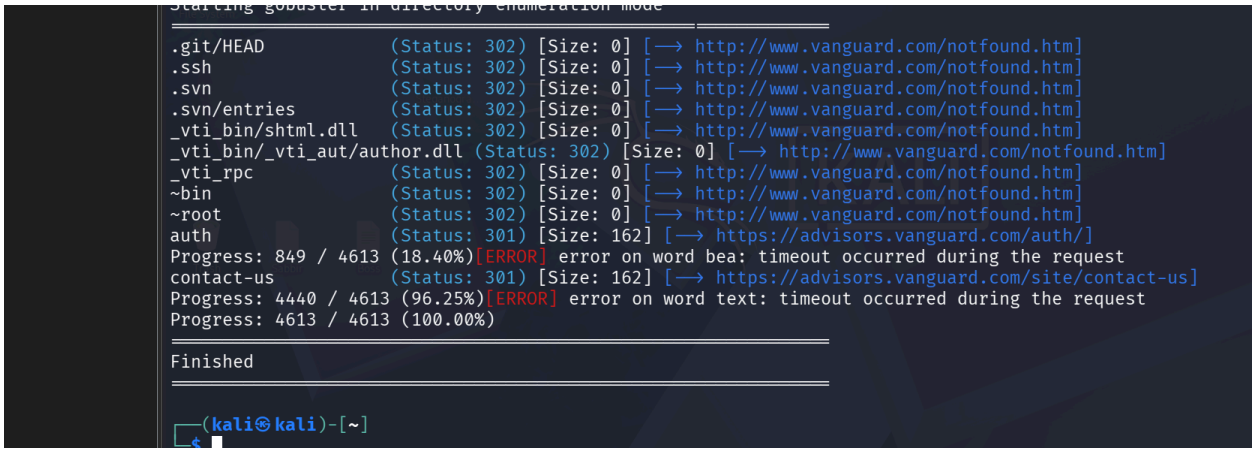
The `/auth` path returned an HTTP 301 redirect to `/auth/`, while `/contact-us` returned an HTTP 301 redirect to `/site/contact-us`. Several other paths returned HTTP 302 redirects to the site's `notfound.htm` page.

The `.git/HEAD`, `.ssh`, and `.svn/entries` results should therefore be treated only as potentially interesting findings. Their actual exposure was not confirmed during reconnaissance.

Which endpoints require further investigation?

The `/auth/` and `/site/contact-us` endpoints are the primary endpoints requiring further investigation because they resolve to application routes. The `.git/HEAD`, `.svn/entries`, and `.ssh` paths are also noteworthy because of their association with version-control or configuration-related resources; however, their 302 responses indicate that exposure was not confirmed.

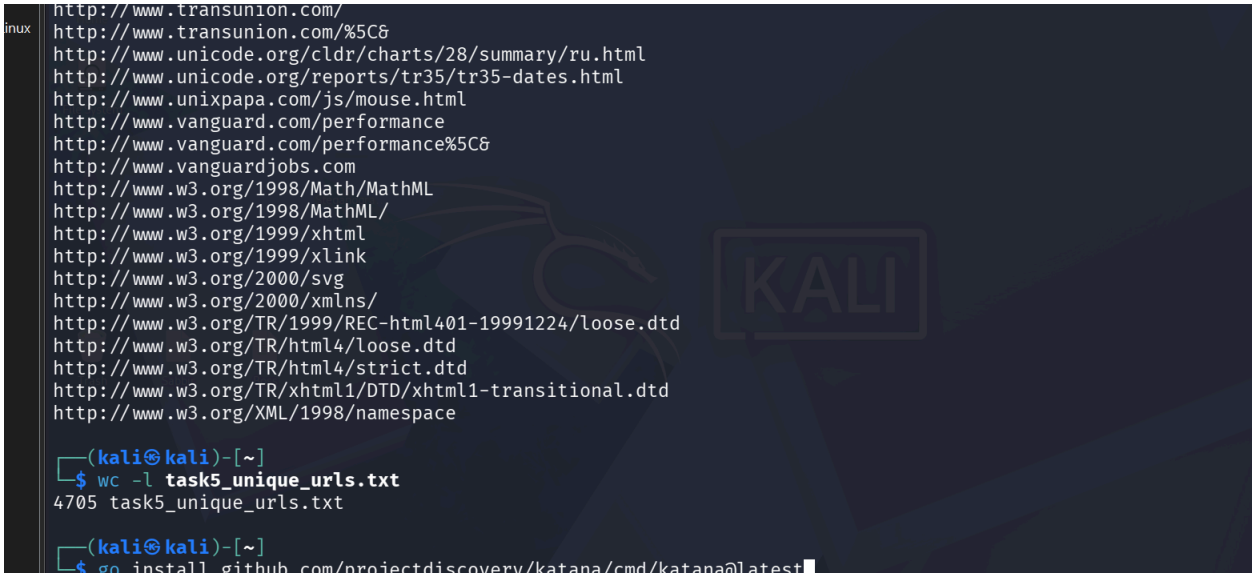




Task 5: URL & Endpoint Discovery

How many unique URLs were collected?

4,705 unique URLs



2. Which endpoints or parameters are interesting?

/api/animations/group

/api/user

/api/weather

/auth/fgb/public/advisors/advisorrepcrd

/auth/fgb/public/advisors/firmNames

/auth/xm1/public/v1/healthcheck

/auth/xm1/public/models/models-ui-data

/auth/xm1/public/download/allocations

/auth/xm1/public/download/performance

/auth/xrg/public/registration/rtelevel

/xrg/api/public/profile/web/certification

3. Were any hidden/API endpoints discovered?

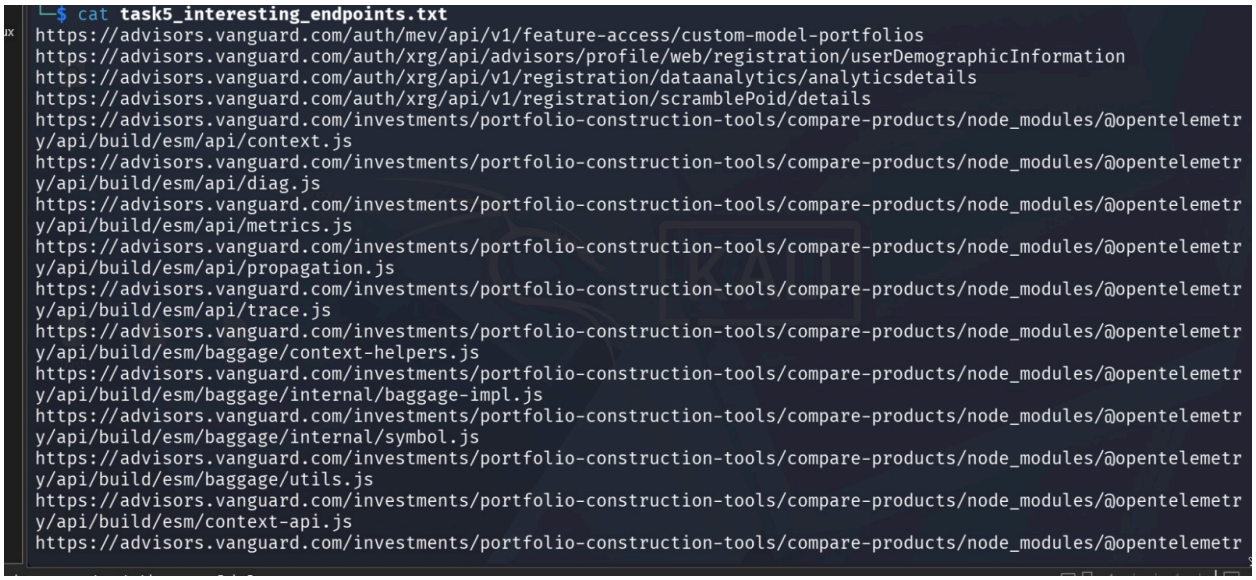
https://advisors.vanguard.com/api/user

https://advisors.vanguard.com/api/weather

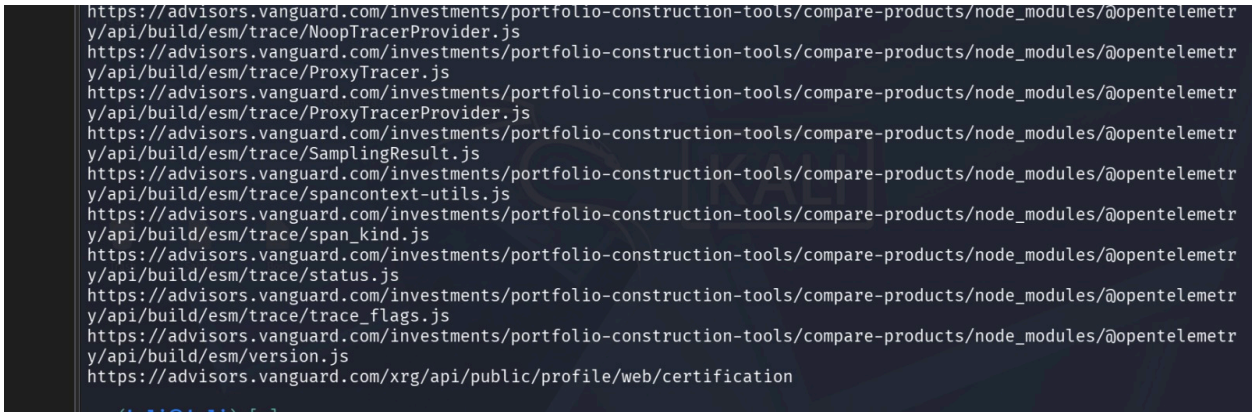
https://advisors.vanguard.com/auth/xm1/public/v1/healthcheck

https://advisors.vanguard.com/auth/xm1/public/models/models-ui-data

https://advisors.vanguard.com/xrg/api/public/profile/web/certification









https://advisors.vanguard.com/api/user

https://advisors.vanguard.com/api/weather

https://advisors.vanguard.com/auth/xm1/public/v1/healthcheck

https://advisors.vanguard.com/auth/xm1/public/models/models-ui-data

https://advisors.vanguard.com/xrg/api/public/profile/web/certification